

SAARE TECHNICAL WHITEPAPER

AI RUNTIME GOVERNANCE & SECURITY INFRASTRUCTURE

NODO CANÓNICO: 2607076315021

NORMATIVA: UNE-EN ISO/IEC 42001

CLASIFICACIÓN: PUBLIC TECHNICAL DOCUMENT

L7 PEP

POLICY ENFORCEMENT POINT

Ex-Ante

DETERMINISTIC INSPECTION

Zero Payload

PERSISTENCE CONTROL

Ed25519

CRYPTOGRAPHIC EVIDENCE

I. EXECUTIVE SUMMARY

The integration of Large Language Models (LLMs) and autonomous agents (MCP) into enterprise infrastructures shifts the traditional security perimeter. Passive observation and *ex-post* log analysis are inherently ineffective at preventing breaches: once a payload containing sensitive data leaves the enterprise network, non-compliance is already consummated. **SAARE Platform** operates as a **Layer 7 Policy Enforcement Point (PEP)** that intercepts, inspects, sanitizes, and routes requests in volatile memory deterministically before reaching external APIs or local model endpoints.

II. THE PROBLEM: RUNTIME AI GOVERNANCE

Agentic workflows interact directly with sensitive data stores, code execution environments, and enterprise APIs. Critical risk vectors include:

- **Prompt & Indirect Injection:** Malicious instruction overrides embedded in agent tools or retrieved context.
- **Ex-Ante PII/PHI Exfiltration:** Inadvertent transmission of credentials, banking records (IBAN) or national IDs (DNI/NIE) to cloud LLM providers.
- **Inference & Resource DoS:** Uncontrolled token consumption or execution loops within MCP agents.
- **Loss of Auditability:** Absence of tamper-evident, signed audit receipts generated ex-ante.

III. SAARE SECURITY MODEL

Inbound Payload → [POSIX Socket / TLS 1.3] → Normalization → Deterministic Inspection → Enforcement [Allow | Sanitize | Block] → Outbound Forwarding

IV. THREAT MODEL & CONTROL CAPABILITIES

THREAT VECTOR	ATTACK SURFACE	SAARE CONTROL	ENFORCEMENT STATE
Direct Prompt Injection	LLM User Input	Policy Pattern & Intent Analysis	Block ex-ante
Indirect Injection	Retrieved RAG / MCP Content	Ex-ante Inspection & Sanitization	Block / Sanitize / Flag
PII / PHI Exfiltration	Outbound API Payloads	Volatile RAM Anonymization	Mask / Redact ex-ante
Replay Attacks	Evidence / API Transactions	Freshness Protocols (Nonces + Timestamps)	Reject transaction
Tampering	Audit Ledger & Logs	Ed25519 Signature + HMAC-SHA256	Verify cryptographic integrity
Inference DoS	Agent Loop Execution	Runtime Circuit Breakers	Reject / Throttle